

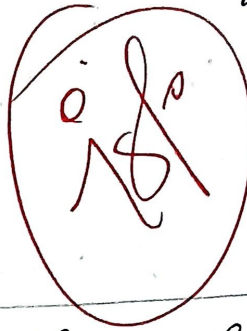
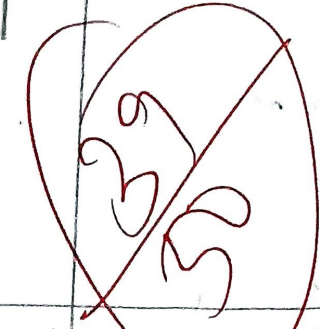
Atchaya Chandran - #2
1425213011

Ethical Hacking

13.08.2026

ITAI1406

CO3 AT3



1.) theHarvester - Reconnaissance of tella.com.

Aim:

To perform passive reconnaissance of the authorized domain tella.com using theHarvester and identify publicly available email addresses, subdomains, subdomains, IP address, URLs and other infrastructure information.

Tool Used:

theHarvester.

Command:

theHarvester -d tella.com -b all.

To have the output:

theHarvester -d tella.com -b all -f tella.com

Information collected:

- Email address → may reveal Employee names and support targeted phishing.
- Subdomains → may expose development, testing, administration or legacy systems.
- Hostnames → help identify different servers and services.
- IP addresses → identify Internet-facing infrastructure.
- URLs → reveal publicly exposed applications and services.
- Certificate/Keystore/Engine information → can reveal additional infrastructure.

Security Analysis:

The most valuable findings are usually Employee Email address, previously unknown subdomains and IP addresses.

Ex. eg.

Email address → Username pattern → Subdomains → Hostname (IP address) → Service identification → Vulnerability Research.

Notes:

- 1.) Employee information can support targeted phishing.
- 2.) Orphaned subdomains can expose forgotten systems.
- 3.) Hostnames reveal infrastructure naming conventions.
- 4.) IP address identify externally accessible systems.
- 5.) Public URLs may expose applications (or) sensitive resources.

Conclusion:

The labshell demonstrates how much information an attacker can obtain without directly attacking the target. Email addresses, subdomains, hostnames, IP addresses and URLs can be combined to map the external attack surface.

2.) Nikto - web application Security Assessment

Aim:

to assess the authorized web application ~~http~~ ~~http~~ . vuln web. com using Nikto and identify exposed files, directories, insecure HTTP methods,

Which information, but also configuration weaknesses.

Tool Used:

Nikto

Command:

nikto -h http://10.10.10.10 -u user -p password

nikto -h http://10.10.10.10 -u user -p password -o nikto-report.txt

Important Findings:

- 1.) Server Version Disclosure → HTTP response headers may reveal the web-server software and version, helping attackers fingerprint the system.
- 2.) Exposed Files and Directories → Backup, .htaccess, administrative or configuration files may disclose sensitive information.
- 3.) Directory Listing - If enabled, attackers may view filenames and application structure.
- 4.) Insecure HTTP Methods - Methods such as PUT, DELETE & TRACE should be reviewed to determine whether they provide unwanted functionality.

Evidence collection:

Finding:

URL:

Evidence:

Severity:

Impact:

Call - I http://telnet.unlweb.com

Call - I http://telnet.unlweb.com.

Finding

Search-Union disclosure

Directly Listing

Exposed Sensitive files

PUT/DELETE allowing

Unauthorized changes

Outdated vulnerable
software

Qualification.

Information disclosure

configuration weakness

Potential vulnerability

Potential / Confirmed

vulnerability

Requires further

Validation.

Conclusion:

Nikto is useful for identifying common web
level weakness and information disclosure. The
most important findings should be manually
validated before being classified as confirmed
vulnerabilities.

3) Dig DNS Enumeration of zone transfer.

Aims

To perform DNS Enumeration of the target domain zone transfer. we using the Dig utility and determine whether an unauthorized DNS zone transfer is possible.

Tool Used:

Dig

Commands Used:

A Record

dig zone transfer. me A

AAAA

dig zone transfer. me AAAA

MX Record

dig zone transfer. me MX

NS Record

dig zone transfer. me NS

CNAME Record

dig zone transfer. me CNAME

TXT Record

dig zonetransfer. me TXT

SOA Record

dig zonetransfer. me SOA

DNS Information Identified:

- A records provide IPv4 addresses of hosts.
- AAAA records provide IPv6 addresses.
- MX records identify mail servers.
- NS records identify authoritative DNS servers.
- CNAME records show relationships between hostnames.
- TXT records may contain SPF and other verification information.
- SOA records provide authoritative DNS and zone-management information.

Zone transfer test:

dig zonetransfer. me NS + Shost.

Then test AXFR

dig @ <authoritative-server> zonetransfer. me AXFR.

Security Risks:

- 1.) All known hostnames and Subdomains
- 2.) Server IP address
- 3.) mail server infrastructure.
- 4.) Internal naming convention.
- 5.) Relationships between different services.

Enumeration Validation:

~~dig @ authoritative - server store & handle the AXFR.~~

Conclusion:

~~Dig provides valuable information about an organization's DNS infrastructure. A successful undetected AXFR can significantly increase information disclosure by revealing hostnames, IP addresses, mail infrastructure and service relationships.~~

4.) Enumeration - Windows / SMB Enumeration

Aim:

~~To assess the authorized Windows / SMB target 192.168.100.1 using Enumeration and identify users, groups, shares, domain information, OS details, password policies and other exposed SMB information.~~

Identified
Penetration
Identified

Penetration 192.168.1.100

Penetration - 192.168.1.100

Penetration - 192.168.1.100 & Penetration

Identified

Information collected:

- 1) U.S. - Identified valid users accounts.
- 2) Example - Shows group and multiple administrative
permissions.
- 3) S.M.S. - Identified shared folders and
local access permissions.
- 4) Domain / Workgroup - reveals various
domain information.
- 5) Operating System - may disclose OS
and service details.
- 6) NetBIOS Information - provides computer and
network names.

Commitment - " - p " " 100-168.

Security Policy:

- Disclosed weaknesses can support password attacks.
- Group information can reveal privileged accounts.
- Accessible SMB shares may expose sensitive files.
- OS information can help attackers identify vulnerabilities.
- Weak password policies increase credential attack risk.
- Effective SMB exposure can facilitate lateral movement.

Priority	Finding	Recommended Action
High	Anonymous Enumeration	Disable unnecessary shares
High	Sensitive share access.	Restrict access
High	Weak password policy	Implement strong authentication controls
High	Effective user	Prevent enumeration

Conclusion:

2

Enum4linux helps identify information exposed through windows SMB and NetBIOS services before exploitation. User accounts, group shares, domain information, and password policies can help an attacker plan credential attacks and lateral movement.

5.) NetCat (nc) - Service and Banner Enumeration of Scanner. nmap.org

Aim:

To use NetCat (nc) against the authorized target Scanner.org to identify accessible TCP services and collect service banners, HTTP headers, software information and other technical details.

Tool used:

Netcat(nc)

Commands Used:

nc -v Scanner.nmap.org 80

HEAD / HTTP/1.1

Host: Scanner.nmap.org

Connection: Close

ne -U scan me . ody & pon-

Information collected:

- 1.) Open TCP service - identified as accessible service.
- 2.) Protocol - indicated HTTP, SSH, FTP etc.
- 3.) Service banner - may reveal software name.
- 4.) Version information - may reveal the software version.
- 5.) HTTP headers - may disclose server and application details.

E.g:

Port:

Service

Protocol:

Banner:

Software / Version:

Response:

IP address → open port → Service →

Software / Version → known vulnerability →

Exploited attack.

Notes:

- help attackers fingerprint exposed services
- reveals software and version information.
- make vulnerability.
- Allow attackers to make subsequent attacks more targeted.

Validation:

nc -U scanner.nmap.org & portc.

Recommended controls:

- Disable unnecessary Internet facing services.
- Restrict services using firewalls
- minimize unnecessary service banner information.
- maintain an inventory of externally accessible service elements.

Conclusion:

Nmap is a simple tool for connecting to TCP services and obtaining their responses. Service banners and HTTP headers can provide useful information for attacker fingerprinting.